
Task 7: Web Application Vulnerability Testing

1. Understanding OWASP Top 10 Vulnerabilities

The **OWASP Top 10** is a list published by the Open Web Application Security Project that highlights the **most critical security risks** affecting web applications. It's widely used by developers, testers, and security teams as a baseline for secure coding and testing.

These vulnerabilities include issues like:

- Injection flaws (e.g., SQL Injection)
- Broken authentication
- Cross-Site Scripting (XSS)
- Security misconfigurations

The goal of understanding the OWASP Top 10 is not to exploit systems, but to **recognize common weaknesses**, understand how attackers abuse them, and learn how to prevent them during development.

2. Setting Up a Vulnerable Application (DVWA / Juice Shop)

To practice safely, testing is done on **intentionally vulnerable applications** such as:

- **DVWA (Damn Vulnerable Web Application)** – designed for learning basic web vulnerabilities.
- **OWASP Juice Shop** – a modern, feature-rich app with real-world scenarios.

These applications are installed locally (often using Docker or a virtual machine), ensuring that **no real systems are harmed**. This controlled environment allows testers to explore vulnerabilities without legal or ethical risks.

3. Intercepting Requests Using Burp Suite

Burp Suite is a web proxy tool used to analyze how a browser communicates with a web application.

When Burp is running:

- Browser requests pass through Burp before reaching the server
- Requests and responses can be viewed and modified
- Parameters like form inputs, headers, and cookies become visible

This helps testers understand how data flows inside the application and identify places where user input is not properly validated.

4. Testing for SQL Injection

SQL Injection occurs when user input is directly included in database queries without proper validation or sanitization.

During testing:

- Input fields (such as login forms or search boxes) are examined
- The goal is to see whether the application behaves unexpectedly when given abnormal input
- Errors, unusual responses, or bypassed authentication can indicate a vulnerability

SQL Injection is dangerous because it can lead to **data leaks, authentication bypass, or database manipulation** if not fixed.

5. Testing for Cross-Site Scripting (XSS)

XSS vulnerabilities allow attackers to inject malicious scripts into web pages that other users view.

Testing focuses on:

- Input fields that reflect user data back onto the page
- Whether the application properly encodes or filters user input
- Observing if the browser executes unexpected scripts

XSS can be used to steal session cookies, perform actions on behalf of users, or deface websites.

6. Observing Application Responses

Careful observation is a key part of vulnerability testing.

Testers look for:

- Error messages revealing internal details
- Differences in responses based on input
- Unexpected redirects or page behavior

Even small details, like verbose error messages, can give attackers valuable information about how the application works internally.

7. Documenting Vulnerabilities

Proper documentation is crucial for fixing security issues.

A good vulnerability report typically includes:

- Vulnerability name and category (e.g., SQL Injection)
- Affected page or functionality
- Description of the issue
- Observed behavior and impact
- Screenshots or logs (if applicable)

Clear documentation helps developers understand the problem and prioritize fixes.

8. Suggesting Mitigations

After identifying vulnerabilities, the final step is recommending **practical security controls**.

Common mitigations include:

- Using parameterized queries to prevent SQL Injection
- Validating and encoding user input to stop XSS
- Implementing proper authentication and access controls
- Disabling detailed error messages in production
- Following secure coding standards and regular security testing

Mitigations turn vulnerability testing into real security improvement, which is the ultimate goal.
